产品需求文档 (PRD)

项目名称：DiffAudit —— 基于成员推断的扩散模型隐私风险检测与安全审计系统

日期：2026 年 4 月 4 日

2. 项目概述

2.1 核心痛点与背景

- **学术背景：**基于提供的文献综述，扩散模型（Diffusion Models）利用 DDIM 等机制在潜在空间（Latent Space）中进行复杂的非线性映射。
- **隐私风险：**模型在生成高质量图像时，可能通过**重建失败（Reconstruction Failure）或过拟合的注意力机制**，意外泄露训练数据中的个人隐私（如人脸、证件）。
- **法规压力：**中国《生成式人工智能服务管理暂行办法》及欧盟 GDPR 均要求模型提供者证明数据合规性。

2.2 产品愿景

DiffAudit 不仅是一个检测工具，更是**扩散模型的“隐私合规护照”**。它利用扩散模型自身的编辑特性（如反演、注意力分析）来“以彼之道还施彼身”，实现高精度的隐私审计。

3. 竞品分析 (Competitive Analysis)

3.1 竞品矩阵分析

维度	**通用 AI 安全平台**（如 IBM Adversarial Robustness Toolbox）	**学术原型工具**（GitHub 开源 MIA 代码）	**DiffAudit（本产品）**
核心功能	侧重传统 CNN 的对抗样本攻击与防御，缺乏针对生成式模型的专项模块。	仅提供命令行脚本，需手动配置环境，无可视化界面，仅支持特定论文实验设置。	**全流程自动化**：支持一键式模型加载、基于 Web 的可视化审计、自动生成合规报告。
检测原理	基于 Loss/Likelihood 的通用统计方法，无法利用扩散模型特有的**潜空间结构**和**去噪轨迹**。	多为简单的黑盒攻击，缺乏利用文献中提到的 **DDIM Inversion** 或 **Attention Map** 的白盒深度分析能力。	**多维深度审计**：1. **黑盒**：基于似然估计 2. **白盒**：基于 DDIM 重建误差 3. **灰盒**：基于 Cross-Attention 热力图分析
适用场景	传统图像分类模型的安全测试。	学术研究复现，无法直接用于企业合规审计。	**企业级合规**：直接对接 Stable Diffusion 等主流扩散模型，输出法律认可的审计证据。
易用性	API 丰富，但需专业算法工程师调用。	极低，仅限科研人员。	**高**：提供图形化界面（Gradio/Streamlit），非技术人员（法务、审计员）可操作。
差异化	无法解决生成式模型的“记忆”问题。	无法解决实际落地的工程化问题。	**填补空白**：首个针对扩散模型潜空间特性的商业化/产品化审计系统。

3.2 DiffAudit 的核心竞争优势（USP）

1. **利用“编辑”反制“隐私”**：直接利用文献中提到的**图像编辑技术**（如 Inversion 和 Attention Manipulation）作为攻击手段，检测准确率远超通用工具。
2. **潜空间（Latent Space）特攻**：不同于竞品在像素空间操作，DiffAudit 在潜空间计算重建误差，效率提升 4-8 倍（基于文献综述中的 Latent Diffusion 理论）。
3. **合规即服务**：直接输出符合《生成式人工智能服务管理暂行办法》的审计报告，这是竞品完全不具备的商业价值。

4. 产品功能需求（MRD & PRD）

结合文献综述中的技术框架，我们将功能细化为四大模块。

4.1 核心审计引擎（Core Audit Engine）

- **功能 1.1：基于 DDIM Inversion 的重建攻击（白盒）**

  需求来源：文献综述中提到的 "Sec2: A significant deviation of z_0 from $\hat{z}_0$, termed reconstruction failure"。

  功能描述：利用 DDIM 反演算法将候选图像 z_0 映射为噪声 z_T，再通过目标模型重新生成 $\hat{z}_0$。

  判定逻辑：计算重建误差 $\|z_0 - \hat{z}_0\|$。若误差极小（无重建失败），则判定该图像极大概率为训练集成员。

  输入：模型权重、候选图像。

  输出：重建误差值、成员概率。

- **功能 1.2：基于 Attention Map 的语义溯源（灰盒）**

  需求来源：文献综述 "Sec2-B" 提到的 Cross-Attention 机制。

  功能描述：在生成过程中 Hook 模型的 Cross-Attention 层，提取注意力热力图。

  判定逻辑：分析敏感区域（如人脸五官）的注意力权重。如果模型在生成特定人脸时，对某些文本 Token 的注意力异常集中，标记为高风险。

  输出：带热力图覆盖的可视化图像。

- **功能 1.3：基于 Likelihood 的黑盒检测**

  功能描述：对于无法获取内部参数的 API 服务，计算模型对输入图像的似然概率（Loss）。

  判定逻辑：成员图像的 Loss 通常显著低于非成员图像。

4.2 可视化与交互模块（UI/UX）

- **功能 2.1：隐私风险仪表盘**

  需求：展示模型的整体隐私风险评分（0-100 分）。

  图表：雷达图展示不同攻击方式（重建、注意力、似然）下的风险值。

- **功能 2.2：风险溯源可视化**

  需求：将复杂的数学矩阵转化为人类可读的图像。

  实现：左侧显示原图，右侧显示生成的 Attention 热力图，中间显示重建过程的 Latent 特征对比。

- **功能 2.3：一键式模型加载器**

需求：支持直接输入 Hugging Face 或 Civitai 的模型链接，自动下载并解析模型结构（.ckpt 或 .safetensors）。

4.3 合规报告生成模块 (Reporting)

- **功能 3.1：标准合规报告**

  需求：基于中国法规生成报告。

  内容：

  - **数据来源声明**：确认模型是否包含特定敏感数据集。
  - **风险等级评估**：依据《生成式人工智能服务管理暂行办法》第 X 条，判定是否通过安全评估。
  - **审计轨迹**：记录所有检测过程的参数和哈希值，确保证据链完整。

- **功能 3.2：防御建议书**

  需求：如果检测出高风险，提供修复建议。

  内容：推荐使用 "Diffence"（推理扰动）或 "LoRA 微调" 等文献中提到的防御手段，并给出具体参数建议。

5. 非功能性需求 (NFR)

类别	需求描述	指标
性能	单样本审计速度	目标：< 10 秒 (利用 Latent Space 加速)
准确性	攻击成功率 (ASR)	目标：AUC > 0.85 (优于传统 Likelihood 方法)
兼容性	模型支持	必须支持 Stable Diffusion 1.5, 2.1, XL, 以及 Custom Checkpoints
安全性	数据隐私	审计过程在本地或私有云进行，用户上传的敏感图片不得外泄
可扩展性	算法插件	支持通过配置文件添加新的 MIA 攻击算法

6. 项目里程碑 (Roadmap)

阶段	时间	关键任务	交付物
Phase 1	第 1-2 周	环境搭建与文献复现	成功复现 DDIM Inversion 代码，跑通 Stable Diffusion 模型加载
Phase 2	第 3-4 周	核心算法验证	实现基于重建误差的 MIA 攻击，准确率达到 Baseline 水平
Phase 3	第 5-6 周	Attention 可视化开发	实现 Cross-Attention Map 的提取与热力图绘制
Phase 4	第 7-8 周	系统集成与 UI 开发	完成 Gradio 界面，实现“上传-检测-报告”闭环
Phase 5	第 9-10 周	大创申报书撰写	基于上述功能点撰写申报书，准备答辩 PPT 和 Demo 视频

7. 风险与应对 (Risk Management)

1. **算力不足风险：**

   风险：扩散模型推理需要大显存 GPU。

   应对：使用 fp16 推理，或利用潜空间（Latent）操作减少计算量；申请学校超算中心资源。

2. **检测误报风险：**

   风险：模型可能因为风格相似而非记忆而产生误报。

   应对：引入“影子模型”（Shadow Model）技术，对比目标模型与无隐私数据模型的差异，降低误报率。

3. **法律风险：**

   风险：测试知名模型（如 SD 1.5）可能涉及版权争议。

   应对：自建小型扩散模型（使用 CelebA 或 FFHQ 数据集训练），专门用于演示“隐私泄露”场景。

8. 附录：基于文献的差异化策略

- **技术护城河**：利用文献中提到的 Latent Space 操作。竞品大多在 Pixel Space 操作，计算量大且效果差；DiffAudit 在 Latent Space 操作，这是扩散模型的核心优势。
- **证据确凿性**：利用 Attention Map。竞品只能告诉你“有风险”，DiffAudit 能告诉你“为什么有风险”（因为模型过度关注了你的眼睛/鼻子特征），这在法律取证上具有决定性优势。